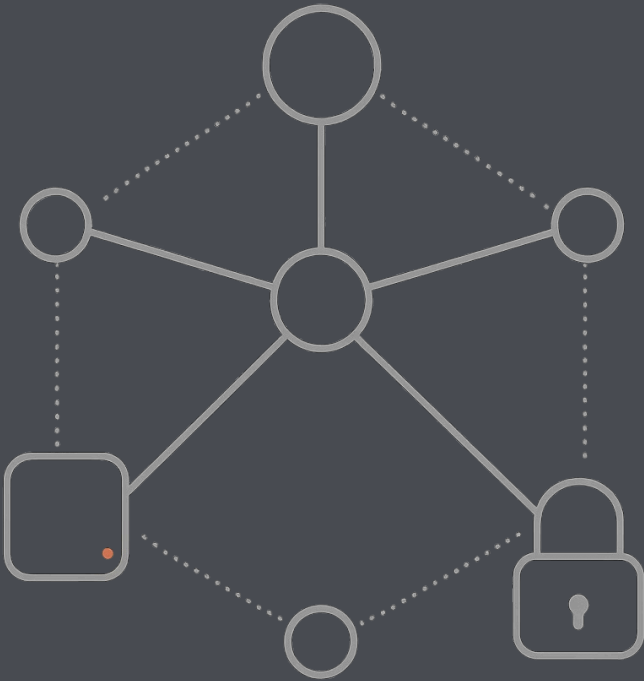
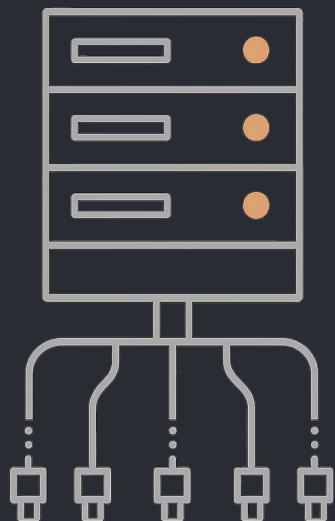




취약점 관리: 정보 출처

성공적인 취약점 관리 프로그램을 운영하려면 여러 데이터 소스의 정보가 필요합니다. 이 장에서는 자산 정보, 취약점 정보, 익스플로잇 데이터, 고급 위협 인텔리전스 등 각 소스를 소개합니다.

완전한 자산 인벤토리가 필요한 이유



많은 조직이 자산 정보를 스프레드시트, CMDB, 엔드포인트 관리 제품으로 관리하지만, 취약점 관리를 위해서는 **IP에 연결된 모든 장치와 각 장치에 대한 추가 정보**를 포함한 완벽한 인벤토리가 필요합니다.

Nmap

네트워크 스캔으로 활성 호스트 탐색

Nessus / Qualys

취약점 스캐너로 추가 정보 수집

스캔 계획과 정기 검색



스캔은 시스템에 부담을 주고 애플리케이션·OS에 충돌을 일으킬 수 있으므로 신중하게 계획해야 합니다. 네트워크에는 새로운 장치가 끊임없이 추가되며, 변경 관리 정책이 있더라도 미준수 변경이 발생할 수 있으므로 **정기적인 검색 스캔**이 필수입니다. 정기 스캔의 위험이 우려된다면 횟수를 줄이고 수동으로 실행한 후 결과를 데이터 저장소로 가져오세요.

변경 관리

변경 관리 시스템의 한계

변경 관리 시스템은 변경 요청, 승인, 조정을 기록하지만, IT 변경에 대한 **유일한 통제 수단**이 되어서는 안 됩니다.

패치 미적용

관리자가 패치를 적용하거나 적용하지 않으면서 기록 누락

네트워크 변경

문제 해결을 위한 경로 추가·변경 시 기록 생략

신규 서비스

비즈니스 요구 충족을 위한 서비스 활성화 시 미기록



취약점 스캔 구성과 범위

스캔 설정 원칙

스캔 시간과 범위를 환경과 위험 허용 수준에 맞게 조정해야 합니다.

→ **엔드포인트 세그먼트** – 매일 스캔 가능 (다운타임 위험 낮음)

→ **핵심 운영 DB** – 유지 관리 시간 외 스캔 위험 높음



취약점 정보

네트워크 스캔의 한계와 보완

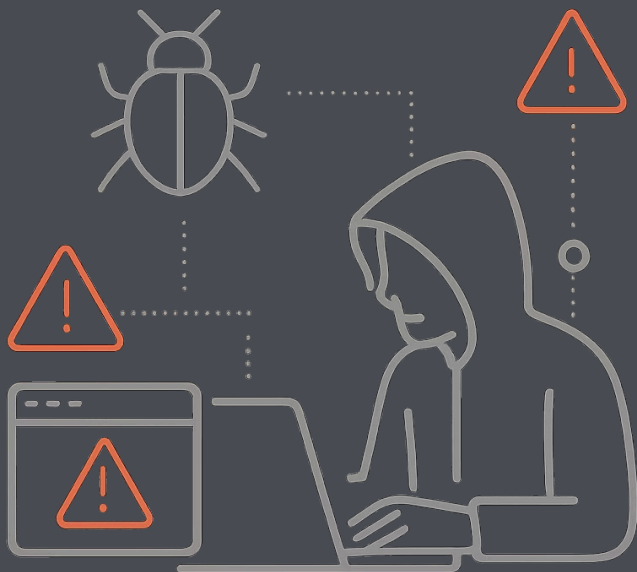
네트워크 취약점 스캐너는 네트워크 연결을 통해 발견 가능한 취약점만 찾아냅니다. 예를 들어, CVE-2018-0862(조작된 Word 문서 열기로 악용 가능한 Microsoft Equation Editor 취약점)는 네트워크 스캔으로 발견되지 않습니다.

엔드포인트 스캐너

Qualys "스캔리스 에이전트" 등

SCM / CMDB

배포된 소프트웨어 버전 목록 수집 후 취약점 DB 참조



데이터 활용

익스플로잇 데이터와 CVE ID

익스플로잇 DB

exploit-db.com — 공개 익스플로잇
검색 색인 제공

Metasploit

익스플로잇 아카이브 + 대상 시스템
배포 도구

CVE ID

cve.mitre.org — CVE-yyyy-xxxx 형식, 익스플로잇과 취약점 매핑

악용 가능한 취약점을 우선 해결하되, 임의 코드 실행은 DoS나 임의 데이터 읽기보다 훨씬 심각한 위협입니다.

위협 인텔리전스와 독점 익스플로잇



위협 인텔리전스 피드

현재 위협 행위자, 익스플로잇 키트, 새롭게 공개된 취약점, iSight, iDefense, FS-ISAC과 같은 산업별 피드 정보 제공.



독점 익스플로잇 정보

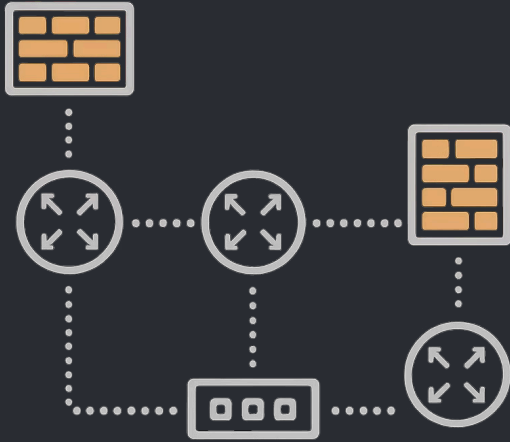
공개 데이터베이스를 넘어서는 상업용 위협 인텔리전스 기업이나 그레이 마켓 연구원의 독점 익스플로잇 데이터를 통해 알려지지 않은 익스플로잇 우선순위 결정 지원.

활용 방법

위협 인텔리전스 피드는 **최신 데이터를 즉시 활용**하여 새롭게 발견된 위협에 대한 노출 정도를 시의적절하게 평가해야 합니다. 독점 익스플로잇 정보는 기존에 알지 못했던 익스플로잇을 기반으로 취약점 데이터의 우선순위를 더 효과적으로 정하는 데 도움이 됩니다.

- ① 무료 및 유료 피드: iSight, iDefense, FS-ISAC 등 업계별 위협 피드 활용 가능

네트워크 구성 데이터



라우터, 방화벽, 관리형 스위치의 네트워크 구성을 활용해 네트워크 모델을 구축할 수 있습니다. 이 정보를 취약점·익스플로잇 데이터와 결합하면 공격 표면을 심층적으로 파악할 수 있습니다.

서브넷 라우팅

어떤 서브넷이 어디로 라우팅되는지

포트 접근 제어

어느 포트에 어디서 접근 가능한지

SolarWinds

중앙 집중식 구성 저장소 활용

취약점 관리용 데이터 소스 한눈에 보기

호스트/포트 스캐너 (Nmap)	IP·MAC 주소, 호스트 이름, 열린 포트, 서비스·OS 지문
네트워크 취약점 스캐너	서비스 버전 감지, 네트워크 취약점, 인증 스캔 시 로컬 취약점
호스트 기반 스캐너	지역적 취약점
CMDB / SCM	OS·소프트웨어·구성 세부 정보, 기기 소유자, 중요도
익스플로잇 DB	익스플로잇 정보, 취약점-익스플로잇 매핑
위협 인텔리전스	공격자 정보, 신규·확산 중인 악용 사례
익스플로잇 키트	독점 익스플로잇 정보
네트워크 구성	네트워크 토폴로지, 잠재적 공격 경로